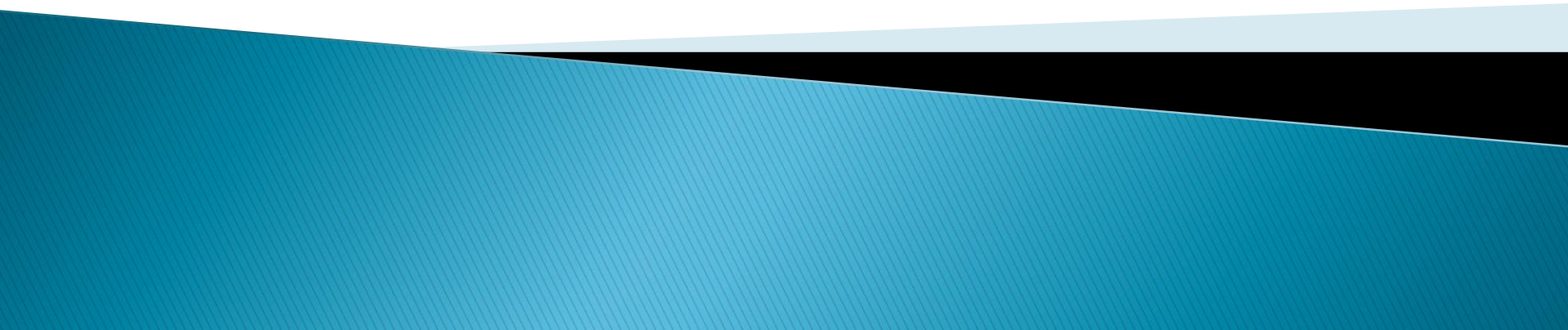


Computer Security and Cyber Law

Unit 9 Database Security

Lecturer: Binod Chandra Shrestha



Issues regarding the right to access information

- ▶ Conflict with privacy.
- ▶ Right to access information is fundamental right of citizen
- ▶ According to Part 3, under Article 27 (Right to information) of constitution of Nepal, 2072
 - Every citizen shall have the right to seek information on any matters of concern to her/him or the public.
 - Provided that nothing shall be deemed to compel any person to provide information about which confidentiality is to be maintained according to law.

Database Security

- ▶ **Database Security** – protection from malicious attempts to steal (view) or modify data.

Importance of Data

- ▶ Bank/Demat accounts
- ▶ Credit card, Salary, Income tax data
- ▶ University admissions, marks/grades
- ▶ Land records, licenses
- ▶ **Data = crown jewels** for organizations

Identity Theft

- ▶ Pretend to be someone else and get credit cards/loans in their name
 - Identification based on “private” information that is not hard to obtain online
- ▶ More lucrative than blue-collar crime,
 - harder to catch criminals
- ▶ Hurts victims even more than regular theft
 - Onus goes on innocent people to prove they didn't get loans or make credit card payment
 - Credit history gets spoilt, making it harder to get future loans
 - And you may have been robbed without ever knowing about it.
- ▶ Increasing risk
 - PAN numbers, names available online

Levels of Data Security

- ▶ Human level: Corrupt/careless User
- ▶ Network/User Interface
- ▶ Database application program
- ▶ Database system
- ▶ Operating System
- ▶ Physical level

Physical/OS Security

▶ Physical level

- Traditional lock-and-key security
- Protection from floods, fire, etc.
 - E.g. WTC (9/11), fires in IITM, WWW conf website, etc.
- Protection from administrator error
 - E.g. delete critical files
- Solution
 - Remote backup for disaster recovery
 - Plus archival backup (e.g. DVDs/tapes)

▶ Operating system level

- Protection from virus/worm attacks critical



Database Encryption

- ▶ E.g. What if a laptop/disk/USB key with critical data is lost?
- ▶ Partial solution: encrypt the database at storage level, transparent to application
 - Whole database/file/relation
 - Unit of encryption: page
 - Column encryption
 - Main issue: key management
 - E.g. user provides decryption key (password) when database is started up
 - Supported by many database systems
 - Standard practice now to encrypt credit card information, and other sensitive information

Security (Cont.)

- ▶ Network level: must use encryption to prevent
 - Eavesdropping: unauthorized reading of messages
 - Masquerading:
 - pretending to be an authorized user or legitimate site, or
 - sending messages supposedly from authorized users



Network Security

- ▶ All information must be encrypted to prevent eavesdropping
 - Public/private key encryption widely used
 - Handled by secure http – https://
- ▶ Must prevent person-in-the-middle attacks
 - E.g. someone impersonates seller or bank/credit card company and fools buyer into revealing information
 - Encrypting messages alone doesn't solve this problem
 - More on this in next slide

Site Authentication

- ▶ Digital certificates are used in https to prevent impersonation/man-in-the middle attack
 - Certification agency creates digital certificate by encrypting, e.g., site's public key using its own private key
 - Verifies site identity by external means first!
 - Site sends certificate to buyer
 - Customer uses public key of certification agency to decrypt certificate and find sites public key
 - Man-in-the-middle cannot send fake public key
 - Sites public key used for setting up secure communication

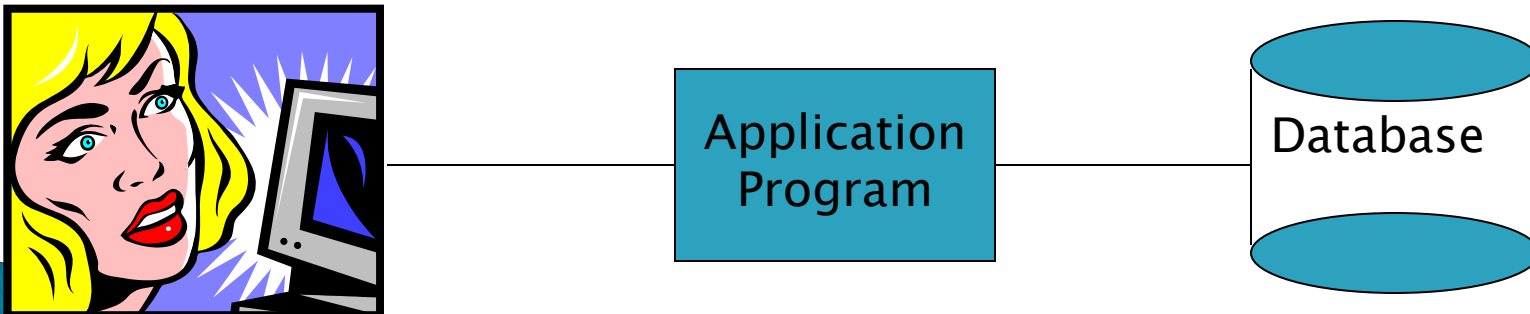
Security at the Database/Application Program

- ▶ Authentication and authorization mechanisms to allow specific users access only to required data
- ▶ Authentication: who are you? Prove it!
- ▶ Authorization: what you are allowed to do



Database vs. Application

- ▶ Application authenticates/authorizes users
- ▶ Application itself authenticates itself to database
 - Database password



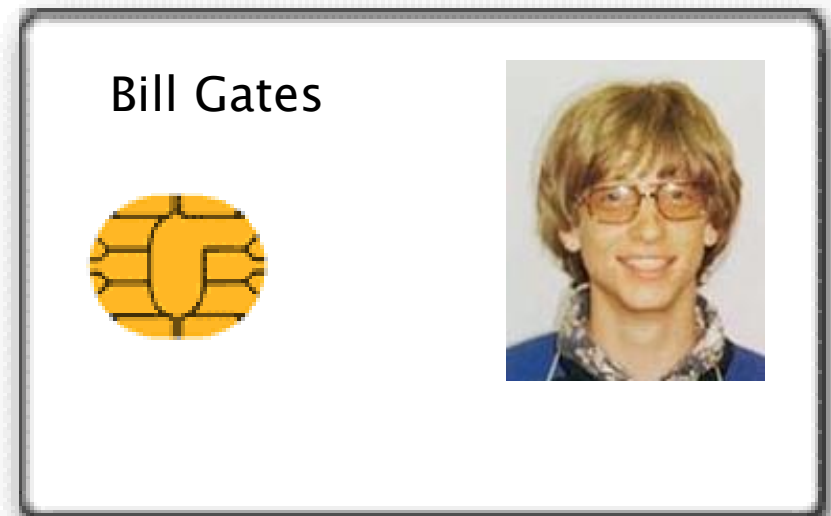
User Authentication

▶ Password

- Most users abuse passwords. For e.g.
 - Easy to guess password
 - Share passwords with others

▶ Smartcards

- Need smartcard
- + a PIN or password

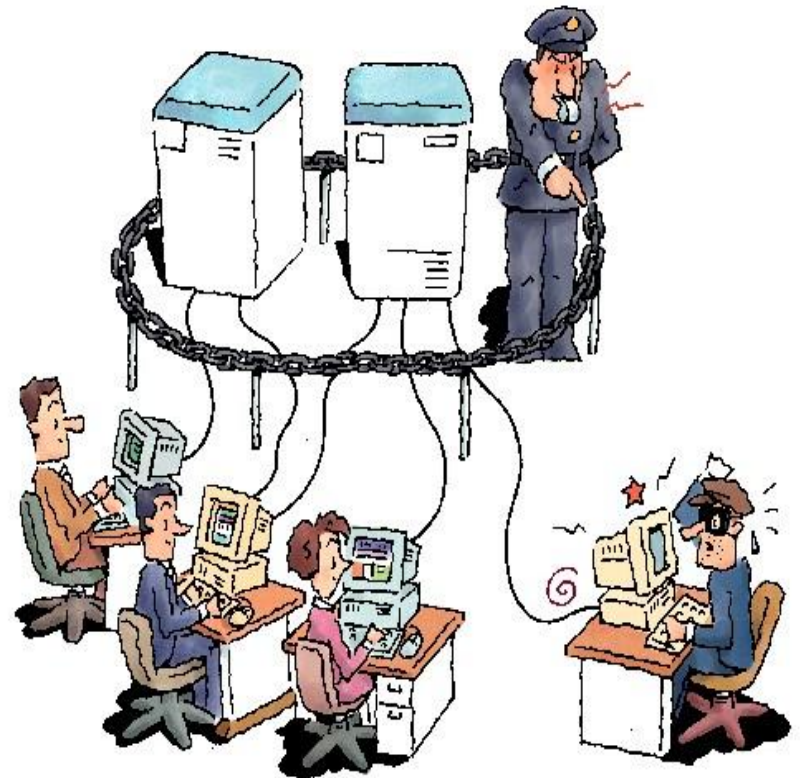


User Authentication

- ▶ Central authentication systems allow users to be authenticated centrally
 - LDAP or MS Active Directory often used for central authentication and user management in organizations
- ▶ Single sign-on: authenticate once, and access multiple applications without fresh authentication
 - Microsoft passport, PubCookie etc
 - Avoids plethora of passwords
 - Password only given to central site, not to applications

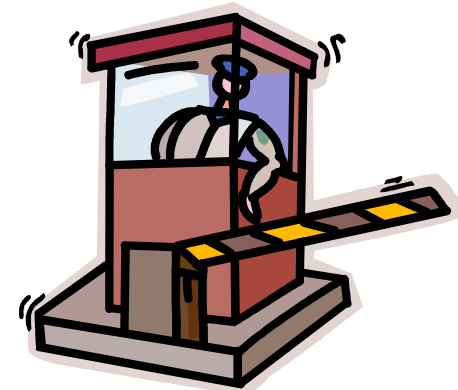
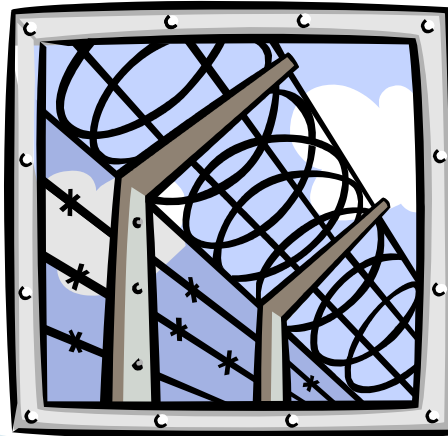
Authorization

- ▶ Different authorizations for different users
 - Accounts clerk vs.
 - Accounts manager vs.
 - End users



Database/Application Security

- ▶ Ensure that only authenticated users can access the system
- ▶ And can access (read/update) only data/interfaces that they are authorized to access



Multi-Level Security (MLS)

- ▶ Protecting sensitive or confidential data is paramount in many businesses. In the event such information is made public, businesses may face legal or financial ramifications. At the very least, they will suffer a loss of customer trust. In most cases, however, they can recover from these financial and other losses with appropriate investment or compensation.
- ▶ The same cannot be said of the defense and related communities, which includes military services, intelligence organizations and some areas of police service. These organizations cannot easily recover should sensitive information be leaked, and may not recover at all. These communities require higher levels of security than those employed by businesses and other organizations.
- ▶ Having information of different security levels on the same computer systems poses a real threat. It is not a straight-forward matter to isolate different information security levels, even though different users log in using different accounts, with different permissions and different access controls.
- ▶ Some organizations go as far as to purchase dedicated systems for each security level. This is often prohibitively expensive, however. A mechanism is required to enable users at different security levels to access systems simultaneously, without fear of information contamination.

Why Multi-Level?

- ▶ The term multi-level arises from the defense community's security classifications: Confidential, Secret, and Top Secret.
- ▶ Individuals must be granted appropriate clearances before they can see classified information. Those with Confidential clearance are only authorized to view Confidential documents; they are not trusted to look at Secret or Top Secret information. The rules that apply to data flow operate from lower levels to higher levels, and never the reverse. This is illustrated below.



Fig Information Security Levels

Types of Security

- ▶ Database security is a broad area that addresses many issues, including the following:
 - Various legal and ethical issues regarding the right to access certain information — for example, some information may be deemed to be private and cannot be accessed legally by unauthorized organizations or persons. In the United States, there are numerous laws governing privacy of information.
 - Policy issues at the governmental, institutional, or corporate level as to what kinds of information should not be made publicly available— for example, credit ratings and personal medical records.
 - System-related issues such as the system levels at which various security functions should be enforced— for example, whether a security function should be handled at the physical hardware level, the operating system level, or the DBMS level.
 - The need in some organizations to identify multiple security levels and to categorize the data and users based on these classifications— for example, top secret, secret, confidential, and unclassified. The security policy of the organization with respect to permitting access to various classifications of data must be enforced.

Threats to Databases

- ▶ Threats to databases can result in the loss or degradation of some or all of the following commonly accepted security goals: integrity, availability, and confidentiality.
 - Loss of integrity.
 - Database integrity refers to the requirement that information be protected from improper modification. Modification of data includes creation, insertion, updating, changing the status of data, and deletion. Integrity is lost if unauthorized changes are made to the data by either intentional or accidental acts. If the loss of system or data integrity is not corrected, continued use of the contaminated system or corrupted data could result in inaccuracy, fraud, or erroneous decisions.
 - Loss of availability.
 - Database availability refers to making objects available to a human user or a program to which they have a legitimate right.
 - Loss of confidentiality.
 - Database confidentiality refers to the protection of data from unauthorized disclosure. The impact of unauthorized disclosure of confidential information can range from violation of the Data Privacy Act to the jeopardization of national security. Unauthorized, unanticipated, or unintentional disclosure could result in loss of public confidence, embarrassment, or legal action against the organization.

Database Security Mechanisms

- ▶ To protect databases against these types of threats, it is common to implement four kinds of control measures:
 - access control,
 - inference control,
 - flow control, and
 - encryption.
- ▶ In a multiuser database system, the DBMS must provide techniques to enable certain users or user groups to access selected portions of a database without gaining access to the rest of the database. This is particularly important when a large integrated database is to be used by many different users within the same organization. For example, sensitive information such as employee salaries or performance reviews should be kept confidential from most of the database system's users.

Database Security Mechanisms

- ▶ A DBMS typically includes a database security and authorization subsystem that is responsible for ensuring the security of portions of a database against unauthorized access. It is now customary to refer to two types of database security mechanisms:
 - Discretionary security mechanisms.
 - These are used to grant privileges to users, including the capability to access specific data files, records, or fields in a specified mode (such as read, insert, delete, or update).
 - ▶
 - Mandatory security mechanisms.
 - These are used to enforce multilevel security by classifying the data and users into various security classes (or levels) and then implementing the appropriate security policy of the organization. For example, a typical security policy is to permit users at a certain classification (or clearance) level to see only the data items classified at the user's own (or lower) classification level. An extension of this is role-based security, which enforces policies and privileges based on the concept of organizational roles.

Control Measures

There are four main control measures used to provide security of data in databases. They are :

1. Access control - The security mechanism of a DBMS must include provisions for restricting access to the database as a whole. This function is called access control and is handled by creating user accounts and passwords to control the login process by the DBMS.
2. Inference control - Statistical databases are used to provide statistical information or summaries of values based on various criteria. Security for statistical databases must ensure that information about individuals cannot be accessed. It is possible to deduce or infer certain facts concerning individuals from queries that involve only summary statistics on groups, consequently this must not be permitted either. This problem is called statistical database security and corresponding control measures are called inference control measures.
3. Flow control - It prevents information from flowing in such a way that it reaches unauthorized users. Channels that are pathways for information to flow implicitly in ways that violate security policy of an organization are called covert channels.
4. Data encryption - It is used to protect sensitive data that is transmitted via some type of communication network. Encryption can be used to provide additional protection for sensitive portions of a database. The data is encoded using some coding algorithm. An unauthorized user who accesses encoded data will have difficulty deciphering it, but authorized users are given decoding or decryption algorithms to decipher data. Encrypting techniques are very difficult to decode without a key have been developed for military applications.

Assignment 9

1. What is database security? Explain legal and ethical issues regarding right to access certain information.
2. Explain different types of database security.
3. Why multi-level security is necessary?
4. Explain the threats to database.
5. Explain about the control measures against the threats to database?